FICHE 22 – *CLOUD* : INFORMATIQUE EN NUAGE

Sécuriser les données et les traitements dans un environnement *cloud*.

Le recours à l'informatique en nuage (*cloud*) est perçu comme un moyen plus rapide et flexible de déployer des nouveaux services. Cependant, les risques spécifiques liés au recours au *cloud* doivent être pris en compte lors de la mise en œuvre d'un traitement de données. Le fournisseur du service *cloud* doit présenter des garanties suffisantes pour assurer la mise en œuvre de mesures de sécurité. Toutefois, le client a également un rôle à jouer pour sécuriser ses données et ses traitements dans le *cloud*, non seulement pour les protéger de tiers malveillants mais également du fournisseur lui-même.

Les précautions élémentaires

- **Cartographier les données et les traitements dans le *cloud*** et maintenir à jour cette cartographie. Inventorier également les services *cloud* utilisés (y compris les applications SaaS). Identifier les ressources *cloud* non utilisées ou non surveillées, et le cas échéant, les retirer.
- Évaluer les besoins en sécurité des traitements mis en œuvre puis choisir :
  - **le mode de déploiement des services** (public, privé, hybride, communautaire, multicloud) adapté ;
  - son fournisseur après avoir **évalué le niveau de sécurité proposé** (notamment en termes de sauvegarde, redondance, chiffrement, sécurité physique, sécurité de la maintenance) par rapport à des spécifications de sécurité *cloud* reconnues.
- **Prendre en compte les services *cloud* dans l'analyse de risques** (voir la fiche n°20 - Analyse de risques), mais également dans les PCA/PRA (voir la fiche n°18 - Prévoir la continuité et la reprise d'activité), tout en tenant compte de ses spécificités.
- **Formaliser les obligations de sécurité et la répartition des responsabilités entre le fournisseur et le client dans un contrat** (voir la fiche n°14 - Gérer la sous-traitance).
- Vérifier que tous **les acteurs impliqués** dans la fourniture du service *cloud* **maintiennent le niveau de sécurité recherché** (le fournisseur lui-même ainsi que ses éventuels prestataires).
- **Configurer les outils de sécurité mis à disposition par le fournisseur le cas échéant** (ex. : chiffrement, gestion des accès et des identités, pare-feu, outil anti-DDoS) en respectant la politique interne de sécurité des systèmes d'information.
- Appliquer les **précautions élémentaires** du présent guide aux traitements dans le *cloud*. En particulier :
  - **chiffrer les données au repos et en transit et avoir une gestion des clés cryptographiques appropriée** (voir la fiche n°21 - Chiffrement, hachage, signature). Il est à noter que l'utilisation des services de gestion de clefs proposés par le fournisseur de service implique que ce dernier a la capacité d'accéder aux données ;
  - **attribuer méticuleusement les accès et autorisations** aux seules personnes habilitées à accéder aux ressources (données et applications) dans le *cloud* et appliquer le principe de moindre privilège (voir la fiche n°5 - Gérer les habilitations) ;
  - **authentifier les utilisateurs pour les accès aux services dans le *cloud*** (voir la fiche n°4 - Authentifier les utilisateurs) et n'accorder que les habilitations nécessaires (voir la fiche n°5 - Gérer les habilitations) ;